WEB APPLICATION PENETRATION TEST — VULNERABILITY REPORT

Cross-Site Request Forgery — Admin State-Changing Actions

Finding NVP-009 · **Medium**

Product: PHPGurukul News Portal Project in PHP and MySQL — V4.1

Assessment target: http://localhost/newsportal/newsportal/

Technology: Apache 2.4.58 · PHP 8.2.12 · MariaDB 10.4.32 (DB user: root)

Assessment date: 2026-10-31

Classification: CONFIDENTIAL — authorised lab assessment (review draft)

Document Control

Finding ID	NVP-009
Vulnerability	Cross-Site Request Forgery — Admin State-Changing Actions
Severity	**Medium**
CVSS 4.0	5.3 `CVSS:4.0/AV:N/AC:L/AT:P/PR:N/UI:A/VC:N/VI:H/VA:L/SC:N/SI:N/SA:N`
CWE	CWE-352 (CSRF)
OWASP	A01:2021 Broken Access Control
CVE verification	No matching publicly assigned CVE was identified for this specific finding and product/version during the research performed.
Status	CONFIRMED (manually validated & re-verified)

1. Executive Summary

Admin state-changing forms and GET actions carry no anti-CSRF token, so a malicious page can force a logged-in admin's browser to create/modify/delete content (and the delete endpoints use GET).

2. Affected Target

Affected URL	Admin add/edit/delete endpoints and change-password.php
Affected parameter	n/a (no anti-CSRF token)
Affected role	Victim: logged-in admin/sub-admin
Authentication	Victim must be authenticated

3. Technical Description

Only the public comment form implements a CSRF token (session token + hash_equals). Admin actions — add/edit/delete posts, categories, sub-admins, change-password — have no token. Several destructive actions are reachable by GET (e.g. manage-posts.php?pid=..&action=del, manage-subadmins.php?rid=..&action=del), so a simple <img>/link suffices.

4. Root Cause Analysis

```
No token generated/validated in admin forms; e.g. admin/manage-posts.php and manage-subadmins.php
perform deletions directly from $_GET with no token and no POST requirement.
```

5. Preconditions

A victim admin/sub-admin with an active session visits an attacker-controlled page.

6. Proof of Concept — Step-by-Step Reproduction

1. Host a page containing e.g. <img src="http://localhost/newsportal/newsportal/admin/manage-posts.php?pid=14&action=del">.
2. A logged-in admin who views the page issues the authenticated request automatically; the post is deleted (soft-delete Is_Active=0).
3. No token blocks the forged request (validated against source + the GET delete behaviour; demonstrated on test post id=14).

7. HTTP Request Evidence

```
GET /newsportal/newsportal/admin/manage-posts.php?pid=14&action=del HTTP/1.1
Host: localhost
Cookie: PHPSESSID=<victim admin>
```

8. HTTP Response Evidence

```
HTTP/1.1 200 OK — post soft-deleted (Is_Active=0); no CSRF validation performed.
```

9. Proof of Concept — Visual Evidence

> **Evidence note:** Confirmed by source review (absence of tokens) and by the GET-based delete behaviour (NVP-015). Demonstrated against the lab test post (id=14) only.

10. Actual Security Impact

An attacker can cause a logged-in administrator to unknowingly create, modify or delete content and accounts, or change passwords, via cross-site requests.

Exploitation complexity	Medium — requires the victim to be authenticated and to load attacker content.
Realistic attack scenario	An attacker emails a link/embeds an image; a logged-in admin triggers destructive admin actions unknowingly.

11. Remediation Recommendations

Add per-session anti-CSRF tokens to every state-changing form and validate them server-side; require POST for mutations; use SameSite=Strict cookies.

Secure code example

```
// generate: $_SESSION['csrf']=bin2hex(random_bytes(32));
// validate: if(!hash_equals($_SESSION['csrf'],$_POST['csrf'])) abort(); // on every mutation
```

12. Retesting Procedure

Replay a forged cross-site request; a fixed system rejects it for a missing/invalid token.

13. References

- CWE-352
- OWASP WSTG-SESS-05
- OWASP A01:2021

14. Conclusion

Confirmed systemic CSRF on admin actions. Verified via source + GET-delete behaviour on test data.